

SEE ALSO Newsletter of February 28, 2025

[doc. web n. 10106904]

Provision of December 19, 2024

Register of provisions

n. 802 of December 19, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting today, attended by

Prof. Pasquale Stanzione, president, Prof.

Ginevra Cerrina Feroni, vice president, Dr.

Agostino Ghiglia and Attorney Guido Scorza, members, and

Dr. Claudio Filippi, deputy secretary general;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016 (hereinafter, "Regulation");

HAVING REGARD to the Code regarding the protection of personal data, containing provisions for the adaptation of the national legal system to Regulation (EU) 2016/679 (Legislative Decree of June 30, 2003, n. 196, as amended by Legislative Decree of August 10, 2018, n. 101, hereinafter "Code");

HAVING REGARD to the inspection assessment carried out on June 13, 2023, at the operational headquarters of Studio Riabilitazione Creditizia s.r.l.s. (hereinafter "Studio Riabilitazione" or "the Company");

HAVING EXAMINED the documentation on record;

HAVING REGARD to the observations made by the secretary general pursuant to Article 15 of the Guarantor's regulation n. 1/2000;

REPORTING Prof. Ginevra Cerrina Feroni;

PREMISED

1. The inspection activity concerning the company.

In the exercise of the control powers referred to in Article 58, paragraph 1 of the Regulation (see also Articles 157 and 158 of the Code), the undersigned Authority has carried out inspection assessments concerning Studio Riabilitazione Creditizia s.r.l.s.

The control activity originated from a report received from the Bank of Italy, which noted that Mr. XX (legal representative of the aforementioned company) had made numerous requests for access to the data of the Central Risks of the same Bank, on behalf of individuals, in the absence of actual legitimacy, with a consequent risk of improper use of personal financial data improperly acquired. At the conclusion of the inspection assessment (see the minutes of operations carried out on 13/6/2023, as well as notes of 28/6/2023 and 3/7/2023, with which the Company, in response to the reservations made during the inspection, transmitted the supplementary documentation), the Office, having identified some critical profiles deserving of further analysis, made a request for information, pursuant to Article 157 of the Code, which, however, remained unanswered (see notes of 4/12/2023 and 23/1/2024); in light of the lack of response, the aforementioned Special Unit, by delegation from the Office (see note of 6/3/2024), notified the Company of the aforementioned request for information - together with the initiation of the sanctioning procedure, pursuant to Article 166, paragraph 5, of the Code, in relation to the violation of Article 157 of the Code - and acquired the requested information (see minutes of operations carried out on 15 and 17/4/2024).

From the aforementioned investigative activity, based on the statements made by the legal representative of the Company, it emerged that:

1. The Company "mainly deals with the cancellation of reports in credit bureaus operated by banks." The clientele primarily identifies the contacts of the Company "through the website www.studioucp.it," where "information on the services offered" is also provided;
2. When "the client contacts the company by phone," they "receive information on data processing

through a pre-recorded voice" that provides them "with some general information about the services offered"; then, "if the client accepts, the receptionist collects the client's data (name, surname, address, email, etc.) in the company database (Customer Relationship Management, hereinafter CRM). In this CRM, additional data that the client provides during the consultancy relationship, or the signed forms sent via email, are also stored." The Company, once it has obtained the delegations from the interested parties, makes "requests for access or inquiries to private and public risk centers (Bank of Italy and Chamber of Commerce) in order to better define the client's debt position" and assess "the feasibility of the cancellation or limitation of the processing of the client's personal data at the risk centers." In the event that it does not find "any element to proceed with the cancellation, it sends the client an additional 'questionnaire' to obtain more details about the reported circumstances"; then "if, from the analysis of the additional data provided, the Company sees the aforementioned feasibility, it issues a cost estimate that is sent to the client via email. If the client accepts the service offered by the Company, the contractual documentation, including attachments, is sent to them by regular mail, so that they can return it, also by courier, signed for acceptance. Then the activity begins at the competent offices to request, for example, the cancellation of the reports";

3. The information referred to in Articles 13 and 14 of the Regulation (of which a copy has been acquired, see attachment 1 to the minutes of 13/6/2023 and, among the attachments, see page 43), in addition to being published on the website www.studioucp.it (see attachment 9 to the aforementioned minutes), is provided to the interested parties both by phone, at the time of the first contact with the Company, and subsequently, at the time of signing.

of the "mandate form" and the delegation to operate on their behalf at public and private risk centers (see mandate contract, delegation, and information on pages 9, 20-22, and 43 of the minutes of operations carried out on 13/6/2023, as well as attachment 8, including page 157). With this, the client is made aware that the legal basis for the processing of personal data lies in Article 6, letter b) of the Regulation and that such data is retained "for the entire duration of the contractual relationship and, after the termination of the relationship, only to the extent necessary for the fulfillment of the obligations contractually assumed and for the execution of all possible legal obligations and for the needs of protection, including contractual, related to or arising from it";

4. The Company, in carrying out its activities, relies on the collaboration of various subjects (natural and legal persons) for whom the privacy roles have not been correctly identified and/or regulated, pursuant to Article 28 of the Regulation. In particular, from the collection of acquired elements, it appears that:

a. the company "Centro Realizzazioni informatiche e finanziarie S.r.l.s." (see minutes of 13/6/2023, page 5) – whose legal representative is always XX - carries out processing of personal data on behalf of and in the interest of Studio Riabilitazione creditizia, in the absence of any act that, considering the professional requirements of the company and taking into account the guarantees it offers for the protection of the rights of the data subjects, binds it to the data controller by defining its obligations and rights, as well as the terms and conditions of the personal data processing carried out;

b. additional subjects intervene "in the process of processing customer data (...)" as data processors pursuant to Article 28 of the Regulation; these include the company "Ufficio Cattivi Pagatori S.r.l.", also attributable to Mr. XX (sole partner of the same) and "some external professionals, legal or tax consultants", whose activity "consists of receiving in paper form the delegation signed by the client and the instructions for the activities to be carried out, for the specific individual case, at the various public offices concerned (e.g., at the chamber of commerce, the protests and bills are provided to the professional) (see attachments 3, 4, and 5 to the minutes of 13/6/2023). Regarding each of these subjects, the Company has prepared a "Letter of appointment as data processor" which expressly refers to a "contract of which it is an integral part"; however, at the specific request of the Office to produce a copy of the contracts in question "or another legal act referred to in Article 28, paragraph 3 of the Regulation", the Company did not provide any supplementary documentation (see minutes of 17/4/24, page 4).

5. During the inspection, a copy of the register of processing activities, prepared pursuant to Article 30 of the Regulation (see attachment 9), was acquired; furthermore, at the request of the Office, the

Company confirmed that it had appointed Dr. XX as the "Data Protection Officer" pursuant to Article 37 of the Regulation (as also found in the information provided to clients), specifying that it had not, however, made the necessary communication to the Authority (see minutes of 13/6/2023, page 6);

6. Regarding the information system, the Company stated that the system in operation consists of 10 client workstations and a server, operating in the premises of the Company itself. Access to the workstations is granted by entering a username and a password. The server operates a CRM (Customer Relationship Management) system for managing the customer database, a customized product developed by an external supplier. From the accesses made on-site, it emerged, among other things, that:

- the "CRM Management" contains positions corresponding to 74,214 customers. For each "customer record," the data present includes name, surname, place and date of birth, tax code, contact details (phone, physical address, email), an identification number ("NRG"), the "status" (i.e., whether it is a "former client" or "new," or "in progress" or "completed") as well as other information related to the status of the practice, including any notes in textual and summary form and the status of payments of invoices issued by the Company, following the processing of the practice;
- in each customer file, there are also reports provided by companies and banking institutions, in response to access requests made by the data subjects through the delegate, Dr. XX or XX (see minutes of 13/6/23, attachment 7).
- access to the CRM occurs through the entry of a masked authentication component (password) (see attachment 3 to the minutes of 13/6/2023) and is only possible from the Company's premises and without any possibility of connecting, via the internet, to the IT systems from outside, "through so-called 'remote desktop' software"; the Company also stated that the "maintenance of the workstations and the CRM software is carried out by an external subject, designated as system administrator, who goes on-site at the Company's premises as needed" (see minutes of 13/6/2023, page 6);
- in the CRM "personal data have also been channeled whose ownership belonged to the various companies that have succeeded each other over the years in providing the same services; such data are consulted from time to time for the functionality of recovering debts for the services provided by the following companies: Ufficio cattivi pagatori srl, UCP srl, Centro realizzazioni informatiche e finanziarie, Insurance Global service srl."

Regarding this matter, the data controller, who was asked to specify which companies currently access — and on what basis — the corporate database and whether there exists, within it, a compartmentalization or functionality that allows tracing back, for each customer, to the company that, as the data controller, collected and thus processed the personal data of the same customer, specified that: "currently, only the company 'Studio Riabilitazione Creditizia S.r.l.s' accesses the CRM, through the mentioned individuals. Over the years, the data of all the companies that have alternated have flowed into the CRM. I have alternated different companies for fiscal reasons and job opportunities. For each of them, I have collected consent from every customer with whom we had working relationships. Consent was collected in paper form. The documentation concerning the consents to date, due to the relocation to different premises, is stored in a cellar and kept in a designated room. I want to clarify that for all the companies that have alternated, I have always been the sole administrator and therefore the data controller. I specify that the mandate given by each customer can be traced back to a single company and the others have never interacted with that customer, even though the data has all flowed into a single CRM. Although over the years the companies have succeeded one another in the same services, the mandate from each individual customer has been given to a single company and only that company has had working relationships with him. There is no functionality in the CRM that allows us to trace back, for each customer, to the company that collected the data. All data flows into the CRM in a general registry. I clarify that in the CRM in question, there are data not only of the individuals who later became our customers, but there are also data of individuals who, through the form on our website, www.ufficiocancellazioneprotesti.it, simply requested information and then did not wish to continue the relationship. Therefore, since they are not customers, their data present in the CRM is minimal (name — surname — phone). To my knowledge, and as confirmed by my collaborator

(...), the customers in the database are about 46,000" (see minutes of 17/4/2024, p. 9);

8. Regarding the retention of data, both in digital format and those kept in paper form, the Company stated that:

- "there are no systematic procedures for the periodic deletion of historical data, and therefore, the company retains complete paper files and digital records, even if it has not had contractual relationships with those subjects for some time; in particular, "for each customer, there is a paper file stored in a cabinet located in the same premises. The oldest files are moved to a designated storage room" (see minutes 13/6/23, pp. 5-6);
- regarding the request to clarify the consistency of the statements above with what is indicated in the information provided to customers pursuant to Articles 13 and 14 of the Regulation and recorded in the register of processing acquired in the records (attachments 1 and 9 to the minutes of 13/6/2023), the Company, while specifying that "our CRM has no commercial purposes and no data concerning customers is used to contact them once our working relationship ends. We only maintain an overall database, into which all data has flowed over the years," also stated that it will "as soon as possible, delete from the corporate CRM all data that no longer have a reason to remain in it having exhausted the fiscal or legal timelines that allow us to retain the data."

2. The initiation of the procedure for the adoption of corrective and sanctioning measures.

In the context of the procedure, the Company received two separate notifications of violation, pursuant to Article 166, paragraph 5 of the Code:

the first, with a note dated March 6, 2024, regarding the violation of Article 157 of the Code, for the failure to respond, within the terms, to the request for information made on January 23, 2024, and duly notified to it by the Financial Police on April 15, 2023;

the second, with a note dated September 3, 2024, regarding the violations of the Regulation found, following the documentation acquired during the investigation, with reference to Articles 5, paragraph 1, letters a), e) and paragraph 2, 14, 24, 28, 37, 38 of the Regulation, notified via PEC on September 3, 2024.

The Company, although invited to submit its defense writings or documents within 30 days of receiving the aforementioned notes (Article 166, paragraphs 6 and 7 of the Code, Article 18 Law 689/1981) - which were correctly notified - did not provide any elements.

3. Outcome of the procedure.

3.1. Observations on the legislation regarding the protection of personal data relevant to the case and established violations.

Following the examination of the statements made to the Authority during the procedure (the veracity of which the author is responsible for pursuant to and for the effects of Article 168 of the Code), as well as the documentation acquired, it appears that Studio Riabilitazione Creditizia s.r.l.s., as the data controller, has carried out processing of customers' personal data that is not compliant with the regulations on the protection of personal data, in relation to the various profiles represented below. In general, it is highlighted that the processing of personal data must occur in compliance with the principles indicated in Article 5, paragraph 1, of the Regulation, including those of "lawfulness, fairness, and transparency" and

"limitation of storage", pursuant to which personal data must be – respectively – "processed lawfully, fairly, and transparently in relation to the data subject", as well as "kept in a form which permits identification of the data subjects for no longer than is necessary for the purposes for which the personal data are processed" (art. 5, par. 1, letters a) and e), of the Regulation).

In particular, the principle of transparency translates into the obligation, on the part of the data controller, to provide the data subject with all the information regarding the processing of personal data concerning them, in an accessible and understandable manner, informing them, at the time when the personal data are obtained, also of the purposes and methods of processing and the legal basis for the same, as well as all further information necessary to ensure that the processing is fair and transparent in accordance with the provisions of articles 13 and 14 of the Regulation (see also Recital 39 of the Regulation).

Article 14, par. 1 and 2 of the Regulation also provides that, in the event that the personal data “are not obtained from the data subject”, the data controller is required to provide the data subject with the information referred to in paragraphs 1 and 2 “within a reasonable period from the obtaining of the personal data, but no later than one month, taking into account the specific circumstances in which the personal data are processed” or, “in the case where the personal data are intended for communication with the data subject, at the latest at the time of the first communication to the data subject; or in the case where communication to another recipient is planned, no later than the first communication of the personal data” (art. 14, par. 3 of the Regulation).

The provisions of the Regulation then specifically identify the subjects – controller, processor – who, in different capacities, may process the personal data of the data subjects, also establishing their respective attributions.

In particular, the controller is the subject on whom the decisions regarding the purposes and methods of processing the personal data of the data subjects fall, as well as a “general responsibility” (accountability) for the processing carried out by themselves or by others who carry out such processing “on their behalf”, namely the processors (rec. 81, arts. 4, point 8) and 28 of the Regulation). The relationship between the controller and the processor must be governed “by a contract or other legal act in accordance with the law of the Union or the Member States, which binds the processor to the controller and stipulates the subject matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects, the obligations and rights of the data controller” (art. 28, par. 3, Regulation).

The controller is also responsible for compliance with the personal data protection legislation, and must, for this purpose, implement appropriate technical and organizational measures to ensure, and be able to demonstrate, that the processing is carried out in accordance with the Regulation; this “taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons” (arts. 5, par. 2 and 24, of the Regulation).

Article 37 of the Regulation (“Designation of the Data Protection Officer”), in providing for the cases in which the designation of the Data Protection Officer (DPO) is mandatory, also establishes that, in any case, even where the DPO is appointed voluntarily by the controller, the DPO “may be an employee of the controller (or the processor) or perform their tasks based on a service contract”.

The “Guidelines on Data Protection Officers (DPOs)” adopted by the Article 29 Working Party on October 13, 2016 (amended on April 5, 2017) indeed provide that where “an organization designates a DPO on a voluntary basis, the requirements of Articles 37 to 39 will apply to their designation, position, and tasks, as if the designation were mandatory” (see point 2.1).

The DPO, whether an employee of the data controller or not, should indeed be able to perform their functions and tasks independently (Rec. 97). The data controller is also required to publish the contact details of the DPO and communicate them to the supervisory authority (art. 37, pars. 6 and 7 Regulation).

According to art. 38 of the Regulation (“Position of the Data Protection Officer”), the DPO must indeed be a subject designated by the controller (or the processor) to perform, in relation to the same, support and control functions, consultative, training, and informative regarding the application of personal data protection legislation, in full independence and autonomy, in the absence of conflicts of interest and without receiving instructions regarding the execution of their tasks, to which they report directly to the hierarchical top of the controller.

3.2. Verified Violations.

3.2.1. Violation of art. 5, par. 1, lett. a) and art. 14 of the Regulation.

Based on the elements acquired during the aforementioned checks, it has been found that the Company holds a database in which the personal data of over 70,000 customers acquired from various companies, belonging to Mr. XX, which have alternated in providing the same customer services over the years, are recorded.

No functionality of the CRM in question allows for

identify, with respect to each client, which company has collected the personal data; the same data is also stored, in an equally undifferentiated manner, in paper files kept at the company's premises or,

with reference to older files, in a warehouse.

In this regard, it is noted that, concerning the personal data of clients whose data was not collected directly by Studio Riabilitazione, but by one or more other companies nonetheless attributable to Mr. XX (and subsequently merged into the CRM of Studio Riabilitazione), the latter, in its capacity as data controller, was unable to demonstrate – during the investigation – that it had informed the data subjects of this transfer by providing the data subjects with the information required by Article 14, paragraphs 1 and 2 of the Regulation, according to the terms established by the subsequent paragraph 3 of the same article.

The conduct of the Company was therefore carried out in violation of the principle of "fairness, correctness, and transparency" as set out in Article 5, paragraph 1, letter a) and Article 14 of the Regulation (see paragraph 3.1).

3.2.2. Violation of Article 5, paragraph 1, letter e) of the Regulation.

It was also established that, at the moment when the client turns to the Company to avail themselves of its services, they receive a notice pursuant to Article 13 of the Regulation in which the essential characteristics of the processing are explicitly stated, including information regarding the retention periods of the data subject to processing (see page 43 of the minutes of 13/6/2023).

In the model of the notice acquired in the records, it is stated that "personal data will be retained for a period not exceeding that strictly necessary to achieve the stated purposes. Personal data for which retention is not necessary or for which retention is not provided for by current legislation, in relation to the stated purposes, will be deleted or transformed into anonymous form. It is highlighted that the information systems used for managing the collected information are configured, from the outset, to minimize the use of data."

On the contrary, however, from the checks carried out - and from the statements made on record by the party (see minutes 13/6/23 pages 5-6) - it emerged that, in fact, the Company has not identified precise retention timelines for the personal data processed, both with reference to those who, by signing a mandate contract, have availed themselves of the Company's services, and with reference to those who have simply requested information, without subsequently establishing any contractual relationship.

In particular, the Company, contrary to what is reported in the notice provided to the data subjects, has never proceeded, after the termination of the contractual relationship, to delete the personal data whose retention is not necessary. This applies particularly to the data of those who, after contacting the Company, did not use its services (which amount to several thousand).

Such conduct is therefore deemed to be in violation of the principle of "data retention limitation," as set out in Article 5, paragraph 1, letter e) of the Regulation, according to which personal data must be retained in a manner that allows for the identification of the data subject for a period not exceeding that necessary to achieve the purposes of the processing.

The principle in question indeed imposes on the data controller the burden of assessing the duration of the processing, in necessary correlation with the specific purposes set out at the time of collection; this is to "ensure that the period of retention of personal data is limited to what is necessary" (see Recital 39 of the Regulation).

Although during the inspection, the Company committed to deleting "from the corporate CRM" "all data that no longer has a reason to remain therein having exhausted the fiscal or legal timelines that allow us to retain the data," no assurance was provided in this regard.

3.2.3. Violation of Article 28 of the Regulation.

During the investigation, it also emerged that certain processing activities are carried out, on behalf of the Company, by certain subjects - natural and legal persons - without the Company having regulated the relationship as required, in accordance with Article 28 of the Regulation.

The data controller may, in fact, legitimately decide to delegate the execution of the processing, on its behalf, to processors (see Article 28 and Recital 81 of the Regulation).

In this case, however, the execution of the processing by a processor should be governed by a contract (or other legal act under Union or Member State law) that binds the processor to the data controller and specifies the subject matter and duration of the processing, the nature and purposes of the processing, the type of personal data and categories of data subjects, the obligations and rights of the data controller.

The processor is therefore authorized to process the data of the data subjects "only on documented instructions from the controller" (see Article 28, paragraph 3, letter a); see also the decision of the Guarantor of January 14, 2021 [web doc. no. 9542113] and, more broadly, on the relationship between the data controller and the processor, see the

"Guidelines 07/2020 on the concepts of data controller and data processor pursuant to the GDPR," adopted by the Personal Data Protection Committee on July 7, 2021.

It is therefore the responsibility of the data controller, by virtue of the general responsibility that rests upon them (Article 24 of the Regulation), to ensure the proper regulation of the relationships between the various parties involved in the processing (see Articles 5, paragraph 2, the so-called "accountability" and 24 of the Regulation).

In this specific case, during the inspection, it emerged that the data controller has relied on the collaboration of certain parties in the absence of the prerequisites established by Article 28 of the Regulation. In particular, as highlighted above (see paragraph 1, point 4, letters a) and b)), these are natural and legal persons who carry out personal data processing on behalf of Studio Riabilitazione Creditizia, without this activity being adequately regulated by a contract or other legal act, or based on a "letter of appointment" which lacks any real and effective content, merely reproducing abstract formulas, mostly taken from the provisions of the Regulation, without specifically identifying the tasks, obligations, and areas of competence of each processor, as instead required by Article 28, paragraph 3, of the Regulation.

For the reasons stated above, it follows that there is a violation, in this specific case, based on the elements acquired and what was confirmed by the Company itself in the terms mentioned above, of Article 28 of the Regulation.

3.2.4. Violation of Articles 37 and 38 of the Regulation.

From the documentation acquired during the proceedings, it also appears that the Company has deemed it necessary to appoint a Data Protection Officer (hereinafter, "DPO") and has identified the same in Dr. XX, legal representative of the company itself. This designation has been communicated to the interested parties through the information notice (both that published on the Company's website and that provided to the clients along with the contract form, see page 43 of the attachments to the minutes of June 13, 2023), while no communication has been made to the Authority, as instead required by Article 37, paragraph 7 of the Regulation.

In this regard, it should be noted that the "Guidelines on Data Protection Officers (DPOs)" adopted by the Article 29 Working Party on October 13, 2016 (amended on April 5, 2017) provide that where "an organization designates a DPO on a voluntary basis, the requirements of Articles 37 to 39 shall apply to their designation, position, and tasks, as if the designation were mandatory" (see point 2.1 of the cited guidelines).

It is also noted that Article 37, paragraph 6 of the Regulation expressly states that the data protection officer may be an employee of the data controller or the processor or may fulfill their tasks based on a service contract.

As provided for in Recital 97, "such data protection officers, whether employees of the data controller or not, should be able to perform their functions and tasks in an independent manner."

It is evident that the role of DPO is therefore entirely incompatible with that of the legal representative

of the company for which they are designated, as the same person who determines the means and purposes of the processing cannot have the necessary independence to also carry out the supervisory tasks regarding compliance with the regulations and the policies of the controller concerning personal data protection, as provided for by Article 39, paragraph 1, letter b), of the Regulation and entrusted to a subject (even internal) to whom, however, a condition of independence must be ensured (see Recital 97).

This is further confirmed by the entirety of the provisions of Article 38 of the Regulation, which, among other things, provides that the controller and the processor ensure that the data protection officer does not receive any instructions regarding the execution of their tasks and reports directly to the top management of the controller or the processor.

The assessment regarding the possible existence of incompatibilities related to the performance of roles that involve decision-making powers regarding personal data processing (as in the case of the legal representative of the company) should have led to the impossibility of completing the designation which, even if made, as in this specific case, is nonetheless null.

Moreover, the failure to communicate the details of the designated DPO to the Authority, as required by Article 37, paragraph 7 of the Regulation, has prevented the Authority from identifying and reporting to the data controller the aforementioned incompatibility.

It is therefore established that the Company has designated an incompatible subject (legal representative) as DPO, in violation of Articles 37, paragraph 6 and 38 of the Regulation, and has failed to communicate the contact details of the DPO to the Authority, in violation of Article 37, paragraph 7 of the Regulation.

3.2.5. Violation of Articles 5, paragraph 2 and 24 of the Regulation.

From the overall violations outlined above, it emerges that the technical and organizational measures overall adopted by the controller to ensure compliance of the processing with the Regulation have not proven adequate to the nature, context, purposes, and risks of the processing in question, setting up, in the hands of the data controller, the violation of the principle of “accountability” as per Articles 5, paragraph 2, and as provided by Article 24 of the Regulation.

According to the aforementioned principle, the data controller is indeed the entity assigned the “general responsibility” for processing, thus bearing the burden of implementing an organizational and management system characterized by real and effective data protection measures that are also demonstrable (see also Recital 74 of the GDPR).

This, primarily, through the correct and timely preparation of the obligations imposed by the Regulation (information, definition of relationships with third parties to whom processing is entrusted on behalf of the controller - data processors -, correct designation of the data protection officer) as well as through the implementation of procedures and organizational practices aimed at ensuring compliance of the processing with the relevant regulations (such as, for example, defining data retention periods and procedures for the automatic deletion of data, as well as procedures for managing requests to exercise rights and complaints, see Article 29 Working Party, WP 173 of July 13, 2010 - Opinion 3/2010 on the principle of accountability, pp. 11-12).

3.2.6. Violation of Article 157 of the Code.

In the course of the investigation, the Company also failed to respond to a request for information made by the Authority, pursuant to Article 157 of the Code and duly notified.

It is highlighted in this regard that the violation in question necessitated the involvement of the Privacy Unit of the Guardia di Finanza, tasked with notifying the acts and collecting the evidentiary elements, resulting in an increase in the procedure in terms of costs and time.

The violation of Article 157 entails, pursuant to Article 166, paragraph 2, of the Code, the application of the administrative sanction referred to in Article 83, paragraph 5 of the Regulation.

4. Conclusions: declaration of unlawfulness of the processing. Corrective measures pursuant to Article 58, paragraph 2, of the Regulation.

For the reasons stated above, the Authority, also noting that the Company has not submitted any defensive observations regarding the findings notified by the Office with the initiation acts of the procedure, believes that there are no elements that allow for overcoming the aforementioned findings and for ordering the archiving of the present procedure, nor do any of the cases provided for by Article 11 of the Garante Regulation No. 1/2019 apply.

The processing of personal data carried out by Studio Riabilitazione Creditizia s.r.l.s. is therefore unlawful, in the terms outlined above, as it was carried out in violation of Articles 5, paragraph 1, letters a) and e), and paragraph 2, 14, 24, 28, 37, and 38 of the Regulation and Article 157 of the Code.

The violation, established in the terms outlined in the reasoning, cannot be considered “minor”, taking into account the nature and severity of the violation itself, which concerned, among other things, the general principles, the responsibility of the data controller, the definition of relationships with data processors, and the designation of the data protection officer, as well as the degree of responsibility and the manner in which the supervisory authority became aware of the violation (see Recital 148 of the Regulation).

The Authority also deemed that the level of severity of the violation is high, in light of all relevant factors in the specific case and, in particular, the nature, severity, and duration of the violation, considering the number of individuals whose personal data have been processed by the Company over time.

Given the corrective powers attributed by Article 58, paragraph 2, of the Regulation, in light of the circumstances of the specific case, it is deemed necessary to prescribe the following corrective measures:

- to establish a procedure regarding the retention of personal data of clients, defining the terms in relation to the purposes of the processing and the criteria for their deletion;
- to proceed with the deletion of personal data of clients whose retention is no longer necessary, particularly regarding the data of those who, after contacting the Company, did not use its services;
- to also proceed, where not already done, with the deletion of all personal data for which the Company has committed itself in this regard during the procedure, as the legally permitted retention periods have expired;
- to properly regulate the relationship with the entities to whom the Company entrusts the processing of personal data on its behalf, by adopting a suitable contract (or another binding legal act) in compliance with what is provided for by Article 28, paragraph 3 of the Regulation;
- to proceed - where the Company intends to designate the Data Protection Officer - to assign the role to a suitable individual, possessing the requirements set forth in Article 37, paragraph 5, in compliance with what is provided for by Articles 38 and 39 of the Regulation.

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and ancillary sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).

At the conclusion of the procedure, it appears that Studio Riabilitazione Creditizia s.r.l.s. has violated Articles 5, paragraph 1, letters a) and e), and paragraph 2, 14, 24, 28, 37, and 38 of the Regulation and Article 157 of the Code.

For the violation of the aforementioned provisions, the application of the administrative sanction is provided.

****Monetary Penalty Provided for by Art. 83 of the Regulation.****

The Authority, pursuant to Art. 58, par. 2, lett. i) of the Regulation and Art. 166 of the Code, has the power to impose an administrative monetary penalty provided for by Art. 83 of the Regulation, through the adoption of an injunction order (Art. 18, Law No. 689 of November 24, 1981), in relation to the processing of personal data carried out by Studio Riabilitazione Creditizia s.r.l.s., which has been

found to be unlawful, as outlined above.

It is deemed necessary to apply paragraph 3 of Art. 83 of the Regulation, which states that “if, in relation to the same processing or related processing, a data controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the administrative monetary penalty shall not exceed the amount specified for the most serious violation,” the total amount of the penalty is calculated so as not to exceed the maximum amount provided for by the same Art. 83, par. 5.

With reference to the elements listed in Art. 83, par. 2, of the Regulation for the purpose of applying the administrative monetary penalty and its quantification, considering that the penalty must “in any case [be] effective, proportionate, and dissuasive” (Art. 83, par. 1 of the Regulation), it is represented that, in this case, the following circumstances have been taken into account:

- in relation to the nature, gravity, and duration of the violations, the nature of the violations has been considered relevant as they concern non-compliance with the general principles of processing, particularly the principles of lawfulness and transparency, limitation of storage, and the general principle of “accountability”;
- with reference to the intentional or negligent nature of the violation and the degree of responsibility of the controller, the conduct of the Company and its degree of responsibility have been considered, as it violated the duty of diligence provided for by the legal framework by not responding to communications sent by the Authority during the proceedings;
- the significant number of individuals whose data is processed by the Company and on whom the effects of the contested violations reflect (approximately 74,000);
- the lack of cooperation with the Authority demonstrated by the Company during the proceedings, which resulted in an aggravation of the proceedings in terms of costs and time;
- in favor of the party, account has been taken of the absence of specific previous violations.

It is also believed that the economic conditions of the offender, determined based on the Company's turnover as per the financial statements for the year 2023, are relevant in this case, considering the aforementioned principles of effectiveness, proportionality, and dissuasiveness to which the Authority must adhere in determining the amount of the penalty (Art. 83, par. 1, of the Regulation).

In light of the above elements and evaluations, it is deemed appropriate, in this case, to apply to Studio Riabilitazione Creditizia S.p.A. the administrative penalty of a payment of an amount equal to €70,000 (seventy thousand).

In this context, it is also considered that, pursuant to Art. 166, par. 7, of the Code and Art. 16, par. 1, of the Authority's Regulation No. 1/2019, the publication of this section containing the injunction order on the Authority's website should proceed, given the nature and number of violations concerning non-compliance with the general principles in the processing of data of thousands of individuals.

****ALL OF THE ABOVE HAVING BEEN STATED, THE AUTHORITY****

pursuant to Art. 57, par. 1, lett. f), of the Regulation, finds the unlawfulness of the processing carried out by Studio Riabilitazione Creditizia s.r.l.s., represented by the legal representative pro tempore, with registered office in Rome, Piazzale Clodio No. 22 - VAT No. 14339591001, for the violation of Arts. 5, par. 1, lett. a), and e) and par. 2, 14, 24, 28, 37, and 38 of the Regulation and Art. 157 of the Code; pursuant to Art. 58, par. 2, lett. d), of the Regulation, orders the Company to comply, within 90 days from the date of notification of this provision, with the prescriptions set forth in par. 4 of this decision, simultaneously requesting to provide, pursuant to Art. 157 of the Code and within the aforementioned term, an adequately documented response regarding the initiatives undertaken; it is represented that any failure to respond may result in the application of the administrative monetary penalty provided for by Art. 83, par. 5, lett. e) of the Regulation;

****ORDERS****

pursuant to Art. 58, par. 2, lett. i) of the Regulation, the same Company to pay the sum of €70,000 (seventy thousand) as an administrative monetary penalty for the violations indicated in this provision;

****ORDERS****

therefore the same Company to pay the aforementioned sum of €70,000 (seventy thousand), according to the methods indicated in the annex, within 30 days from the notification of this provision,

under penalty of the adoption of the consequent executive acts pursuant to Art. 27 of Law No. 689/1981.

It is represented that pursuant to Art. 166, par. 8 of the Code, the offender retains the right to settle the dispute by paying - always according to the methods indicated in the annex - an amount equal to half of the imposed penalty within the term referred to in Art. 10, par. 3, of Legislative Decree No. 150 of September 1, 2011.

provided for the submission of the appeal as indicated below.

ORDERS

pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Guarantor No. 1/20129, the publication of the injunction order on the Guarantor's website;

pursuant to Article 154-bis, paragraph 3, of the Code and Article 37 of the Regulation of the Guarantor No. 1/20129, the publication of this provision on the Guarantor's website;

pursuant to Article 17 of Regulation No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Article 78 of the Regulation, as well as Articles 152 of the Code and 10 of Legislative Decree No. 150/2011, against this provision an appeal may be filed with the ordinary judicial authority, with a petition submitted to the ordinary court of the place identified in the same Article 10, within thirty days from the date of communication of the provision itself, or sixty days if the appellant resides abroad.

Rome, December 19, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Cerrina Feroni

THE DEPUTY SECRETARY GENERAL

Filippi